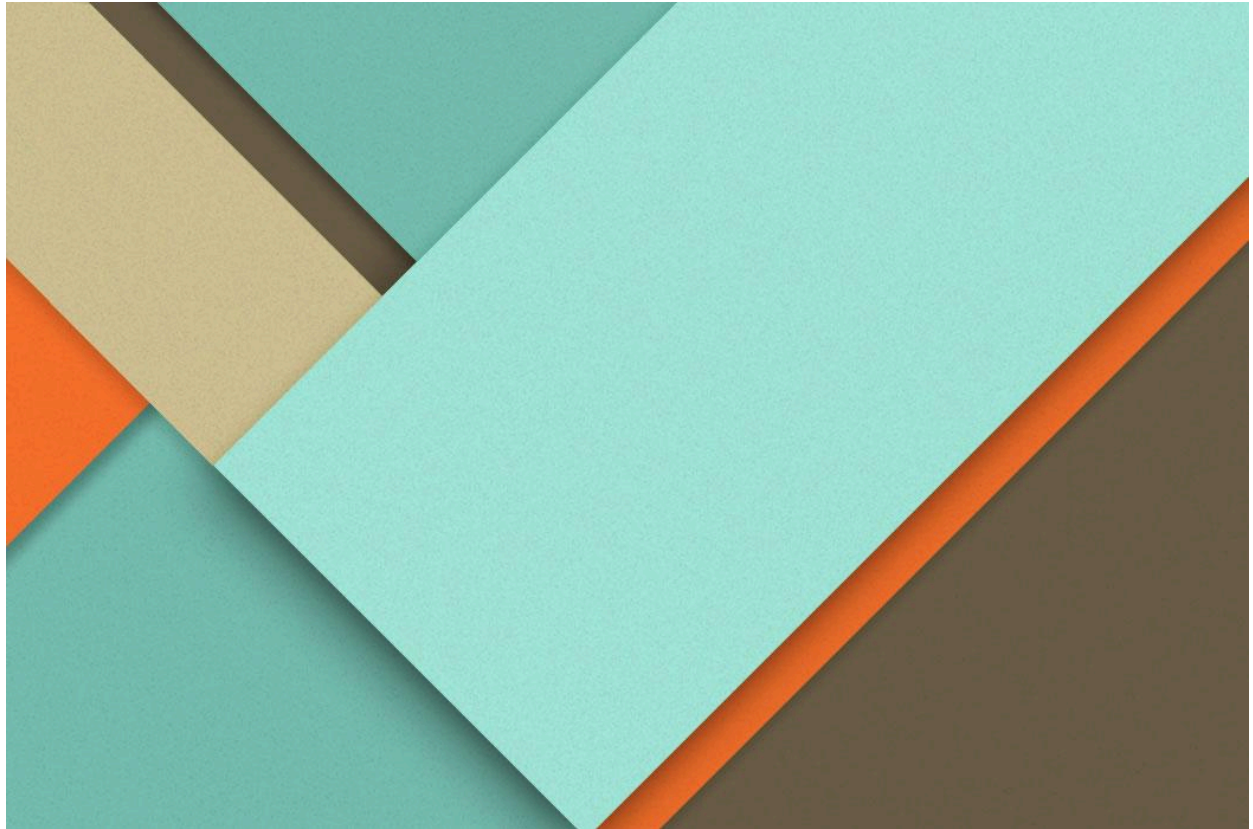




Gestión Integral de un Incidente Crítico de Seguridad

21/07/2025

Ángel Moreno García

CodeArts Solutions

Madrid

Introducción

Este informe documenta el análisis forense realizado sobre un sistema **Linux** que mostró indicios de compromiso. El objetivo es detectar el origen del incidente, preservar y analizar las evidencias, eliminar la amenaza y aplicar medidas preventivas para evitar futuros ataques. A lo largo del informe se describen todas las fases ejecutadas, las herramientas utilizadas, los hallazgos obtenidos y las acciones tomadas para recuperar y proteger el sistema.

Fase 1: Detección y análisis forense inicial

El objetivo es identificar indicios de compromiso (IoC) mediante el análisis de logs, comandos del sistema y observación de procesos activos. Para ello realizaremos una revisión de logs inicial:

Revisión de logs:

- `/var/log/auth.log`: detección de intentos de acceso fallidos y accesos exitosos sospechosos.
- `/var/log/syslog`: mensajes del sistema que indican actividad irregular.
- `/var/log/apache2/access.log` y `error.log`: rastreo de peticiones HTTP anómalas.
- `journalctl -xe`: eventos recientes con errores críticos.

Para ello, ejecutaremos en la consola los siguiente comandos:

`less /var/log/syslog`

`less /var/log/auth.log`

`journalctl -xe`

```
angelserver@srv-base-angel:~$ less /var/log/syslog
less /var/log/auth.log
less /var/log/apache2/access.log
less /var/log/apache2/error.log
journalctl -xe
```

Buscaremos los siguientes indicadores:

- IPs externas con múltiples intentos de acceso.
- Binarios ejecutados desde directorios temporales (/tmp, /dev/shm).
- Procesos sospechosos sin binario asociado o con nombres disfrazados.

```
2025-07-17T12:43:51.642812+02:00 srv-base-angel systemd[1]: rsyslog.service: Sent
signal SIGHUP to main process 1159 (rsyslogd) on client request.
2025-07-17T12:43:51.643246+02:00 srv-base-angel rsyslogd: [origin software="rsys
logd" swVersion="8.2412.0" x-pid="1159" x-info="https://www.rsyslog.com"] rsyslo
gd was HUPed
2025-07-17T12:43:51.686160+02:00 srv-base-angel logrotate[5177]: SARG: Ignoring
old log file /var/log/squid/access.log
2025-07-17T12:43:51.686276+02:00 srv-base-angel logrotate[5177]: SARG: Unknown o
ption resolve_ip
2025-07-17T12:43:51.697321+02:00 srv-base-angel logrotate[5181]: 2025/07/17 12:4
3:51| Processing Configuration File: /etc/squid/squid.conf (depth 0)
2025-07-17T12:43:51.697627+02:00 srv-base-angel logrotate[5181]: 2025/07/17 12:4
3:51| Processing Configuration File: /etc/squid/conf.d/debian.conf (depth 1)
2025-07-17T12:43:51.709675+02:00 srv-base-angel logrotate[5181]: 2025/07/17 12:4
3:51| Set Current Directory to /var/spool/squid
2025-07-17T12:43:51.711940+02:00 srv-base-angel squid[1873]: Closing Pinger sock
et on FD 20
2025-07-17T12:43:51.712090+02:00 srv-base-angel squid[1873]: storeDirWriteCleanL
ogs: Starting...
2025-07-17T12:43:51.712142+02:00 srv-base-angel squid[1873]: Finished. Wrote
0 entries.
2025-07-17T12:43:51.712177+02:00 srv-base-angel squid[1873]: Took 0.00 seconds
( 0.00 entries/sec).
/var/log/syslog
```

```
2025-07-17T12:45:01.749186+02:00 srv-base-angel CRON[5198]: pam_unix(cron:session
n): session opened for user root(uid=0) by root(uid=0)
2025-07-17T12:45:01.757340+02:00 srv-base-angel CRON[5198]: pam_unix(cron:session
n): session closed for user root
2025-07-17T12:47:55.456254+02:00 srv-base-angel gdm-password: gkr-pam: unlocked
login keyring
2025-07-17T12:48:25.709688+02:00 srv-base-angel sudo: angelserver : TTY=pts/0 ;
PWD=/home/angelserver ; USER=root ; COMMAND=/usr/bin/apt update
2025-07-17T12:48:25.712012+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
ssion opened for user root(uid=0) by angelserver(uid=1000)
2025-07-17T12:48:33.852290+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
ssion closed for user root
2025-07-17T12:48:33.864666+02:00 srv-base-angel sudo: angelserver : TTY=pts/0 ;
PWD=/home/angelserver ; USER=root ; COMMAND=/usr/bin/apt install lynis -y
2025-07-17T12:48:33.864942+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
ssion opened for user root(uid=0) by angelserver(uid=1000)
2025-07-17T12:48:35.037803+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
ssion closed for user root
2025-07-17T12:48:35.050315+02:00 srv-base-angel sudo: angelserver : TTY=pts/0 ;
PWD=/home/angelserver ; USER=root ; COMMAND=/usr/sbin/lynis audit system
2025-07-17T12:48:35.051052+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
ssion opened for user root(uid=0) by angelserver(uid=1000)
2025-07-17T12:50:13.437209+02:00 srv-base-angel sudo: pam_unix(sudo:session): se
/var/log/auth.log
```

```
[Thu Jul 17 12:43:51.342301 2025] [mpm_prefork:notice] [pid 1733:tid 1733] AH001
63: Apache/2.4.63 (Ubuntu) configured -- resuming normal operations
[Thu Jul 17 12:43:51.342346 2025] [core:notice] [pid 1733:tid 1733] AH00094: Com
mand line: '/usr/sbin/apache2'
[Thu Jul 17 13:05:45.265078 2025] [mpm_prefork:notice] [pid 1733:tid 1733] AH001
70: caught SIGWINCH, shutting down gracefully
[Thu Jul 17 13:05:45.429402 2025] [mpm_prefork:notice] [pid 62736:tid 62736] AH0
0163: Apache/2.4.63 (Ubuntu) configured -- resuming normal operations
[Thu Jul 17 13:05:45.429510 2025] [core:notice] [pid 62736:tid 62736] AH00094: C
ommand line: '/usr/sbin/apache2'
[Thu Jul 17 14:18:09.020936 2025] [mpm_prefork:notice] [pid 62736:tid 62736] AH0
0170: caught SIGWINCH, shutting down gracefully
[Tue Jul 22 11:41:01.938271 2025] [mpm_prefork:notice] [pid 1690:tid 1690] AH001
63: Apache/2.4.63 (Ubuntu) configured -- resuming normal operations
[Tue Jul 22 11:41:01.981452 2025] [core:notice] [pid 1690:tid 1690] AH00094: Com
mand line: '/usr/sbin/apache2'
```

```
angelserver@srv-base-angel:~$ grep "Failed password" /var/log/auth.log | awk '{p
rint $(NF-3)}' | sort | uniq -c | sort -nr | head
```

```
angelserver@srv-base-angel:~$ ps aux | grep -E "/tmp|/dev/shm"
angelse+  5446  0.0  0.0  6896  2464 pts/0    S+   11:46   0:00 grep --color=
auto -E /tmp|/dev/shm
angelserver@srv-base-angel:~$
```

```
angelserver@srv-base-angel:~$ stat /etc/passwd /etc/shadow
diff /etc/passwd /var/backups/passwd.bak
  File: /etc/passwd
  Size: 3268          Blocks: 8          IO Block: 4096   regular file
Device: 252,0    Inode: 562622      Links: 1
Access: (0644/-rw-r--r--)  Uid: (    0/   root)   Gid: (    0/   root)
Access: 2025-07-22 11:40:56.288999434 +0200
Modify: 2025-07-17 13:09:29.091349634 +0200
Change: 2025-07-17 13:09:29.114510850 +0200
 Birth: 2025-07-17 13:09:29.090510599 +0200
  File: /etc/shadow
  Size: 1641          Blocks: 8          IO Block: 4096   regular file
Device: 252,0    Inode: 562623      Links: 1
Access: (0600/-rw-----)  Uid: (    0/   root)   Gid: (   42/ shadow)
Access: 2025-07-22 11:40:59.134999227 +0200
Modify: 2025-07-17 13:09:29.096510661 +0200
Change: 2025-07-17 13:09:29.114510850 +0200
 Birth: 2025-07-17 13:09:29.095510651 +0200
diff: /var/backups/passwd.bak: No such file or directory
angelserver@srv-base-angel:~$
```

Para ver herramientas de trazabilidad:

who

last

netstat -tulnp

ss -tulwn

lsof -i

```
angelserver@srv-base-angel:~$ who
last
netstat -tulnp
ss -tulwn
lsof -i
angelserver seat0      2025-07-22 11:41
angelserver tty2       2025-07-22 11:41
Command 'last' not found, did you mean:
  command 'fast' from snap fast (0.0.4)
See 'snap info <snapname>' for additional versions.
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address          State
PID/Program name
tcp        0      0 10.0.2.15:53            0.0.0.0:*                LISTEN
-
tcp        0      0 127.0.0.1:631            0.0.0.0:*                LISTEN
-
tcp        0      0 127.0.0.1:53            0.0.0.0:*                LISTEN
-
tcp        0      0 0.0.0.0:25              0.0.0.0:*                LISTEN
```


Fase 2: Aislamiento y preservación de la evidencia

(Esta fase no se puede realizar en un entorno virtual debido a la necesidad de un entorno real y un usb para montar la imagen forense. Se detallarán los pasos a seguir pero no los resultados debido a esto.)

En esta fase buscaremos proteger el sistema de nuevos daños y preservar las evidencias de forma íntegra para su análisis posterior.

Desconexión de red

Necesitamos desconectar nuestro equipo o servidor de la red para realizar las siguientes acciones de seguridad, para ello introduciremos en la consola:

ip link set eth0 down

o firewall temporal:

iptables -A INPUT -j DROP

iptables -A OUTPUT -j DROP

```
angelserver@srv-base-angel:~$ ifconfig eth0 down # o
nmcli networking off # o
iptables -A INPUT -j DROP && iptables -A OUTPUT -j DROP
```

Creación de imagen forense

Crearemos una imagen forense en una unidad usb para el diagnóstico:

dd if=/dev/sda of=/mnt/usb/imagen-forense.img bs=4M status=progress

```
angelserver@srv-base-angel:~$ dd if=/dev/sda of=/mnt/usb/imagen-forense.img bs=4
M status=progress
```

Verificación de integridad

Verificaremos el resultado de la imagen con el comando:

sha256sum /mnt/usb/imagen-forense.img > hash.txt

```
angelserver@srv-base-angel:~$ sha256sum /mnt/usb/imagen-forense.img > hash.txt
```

Montaje en modo lectura

Montaremos la unidad en modo lectura para evitar cambios en el diagnóstico:

mount -o ro,loop imagen-forense.img /mnt/forense

```
angelserver@srv-base-angel:~$ mount -o ro,loop imagen-forense.img /mnt/forense
```

Fase 3: Análisis profundo y cronología del ataque

En esta fase buscaremos identificar malware, técnicas de persistencia, escalada de privilegios y construir una cronología precisa del ataque.

Escaneo del sistema con herramientas

Usaremos las herramientas *chkrootkit*, *rkhunter* y *clamscan* para el escaneo. Introduciremos en la consola:

chkrootkit

rkhunter --check

clamscan -r /mnt/forense

```
angelserver@srv-base-angel:~$ chkrootkit
rkhunter --check
clamscan -r /mnt/forense
/usr/sbin/chkrootkit needs root privileges: some checks may not work
ROOTDIR is '/'
Checking `amd'... not found
Checking `basename'... not infected
Checking `biff'... not found
Checking `chfn'... not infected
Checking `chsh'... not infected
Checking `cron'... not infected
Checking `crontab'... not infected
Checking `date'... not infected
Checking `du'... not infected
Checking `dirname'... not infected
Checking `echo'... not infected
Checking `egrep'... not infected
Checking `env'... not infected
Checking `find'... not infected
Checking `fingerd'... not found
Checking `gpm'... not found
Checking `grep'... not infected
Checking `hdparm'... not infected
Checking `su'... not infected
```

(Los siguientes pasos de esta fase sólo pueden realizarse bajo una amenaza ya que habría registros que analizar, se detallaran los pasos a seguir pero en un entorno virtual se imposibilita la realización del ejercicio)

Búsqueda de SUID y escalada de privilegios

Buscaremos los SUID y realizaremos una escalada de privilegios para aumentar la seguridad ante ataques. Para realizarlo usaremos:

find /mnt/forense -perm -4000 -type f 2>/dev/null

grep 'sudo' /mnt/forense/var/log/auth.log

```
angelserver@srv-base-angel:~$ find /mnt/forense -perm -4000 -type f 2>/dev/null  
grep 'sudo' /mnt/forense/var/log/auth.log
```

Línea de tiempo del ataque

Construiremos una cronología del ataque de manera precisa con:

find /mnt/forense -type f -printf '%TY-%Tm-%Td %TT %p\n' | sort > timeline.txt

```
angelserver@srv-base-angel:~$ find /mnt/forense -type f -printf '%TY-%Tm-%Td %TT  
%p\n' | sort > timeline.txt
```

Fase 4: Erradicación y reconstrucción del entorno

Para asegurarnos de crear un entorno seguro, en esta fase buscaremos eliminar completamente la amenaza, restaurar servicios confiables y fortalecer la configuración del sistema.

Eliminación de elementos maliciosos

Buscaremos eliminar de manera segura todos los elementos que puedan resultar dañinos. Empezaremos ejecutando:

sudo userdel -r atacante (nombre del user atacante)

rm -rf /tmp/malware

```
angelserver@srv-base-angel:~$ userdel -r atacante
rm -rf /tmp/malware
```

Reinstalación desde fuentes seguras

Volveremos a instalar *ssh-server* y *apache2*, para ello introduciremos en la consola:

sudo apt install --reinstall openssh-server apache2

```
angelserver@srv-base-angel:~$ sudo apt install --reinstall openssh-server apache2
[sudo] password for angelserver:
Summary:
  Upgrading: 0, Installing: 0, Reinstalling: 2, Removing: 0, Not Upgrading: 19
  Download size: 715 kB
  Space needed: 0 B / 3.530 MB available

Des:1 http://archive.ubuntu.com/ubuntu plucky-updates/main amd64 apache2 amd64 2
.4.63-1ubuntu1.1 [90,4 kB]
Des:2 http://archive.ubuntu.com/ubuntu plucky-updates/main amd64 openssh-server
amd64 1:9.9p1-3ubuntu3.1 [625 kB]
Descargados 715 kB en 0s (1.554 kB/s)
Preconfigurando paquetes ...
(Leyendo la base de datos ... 198885 ficheros o directorios instalados actualmen
te.)
Preparando para desempaquetar .../apache2_2.4.63-1ubuntu1.1_amd64.deb ...
Desempaquetando apache2 (2.4.63-1ubuntu1.1) sobre (2.4.63-1ubuntu1.1) ...
Preparando para desempaquetar .../openssh-server_1%3a9.9p1-3ubuntu3.1_amd64.deb
```


Aplicación de hardening

Aplicaremos la técnica de hardening configurando SSH y fail2ban:

- Configuración de SSH:

PermitRootLogin no

PasswordAuthentication no

AllowUsers angelserver (nombre de tu usuario)

```
GNU nano 8.3 /etc/ssh/sshd_config *
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

LoginGraceTime 1m
PermitRootLogin no
StrictModes yes
MaxAuthTries 3
MaxSessions 2

PubkeyAuthentication yes
```

```
GNU nano 8.3 /etc/ssh/sshd_config *
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication no
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication no
```

```
GNU nano 8.3 /etc/ssh/sshd_config *
#ChrootDirectory none
#VersionAddendum none

# no default banner path
Banner /etc/issue.net

# Allow client to pass locale environment variables
AcceptEnv LANG LC_*

# override default of no subsystems
Subsystem sftp /usr/lib/openssh/sftp-server

# Example of overriding settings on a per-user basis
#Match User anoncvs
#    X11Forwarding no
#    AllowTcpForwarding no
#    PermitTTY no
#    ForceCommand cvs server
AllowUsers angelserver
```

- Instalación de fail2ban:

sudo apt install fail2ban

```
angelserver@srv-base-angel:~$ sudo apt install fail2ban
fail2ban ya está en su versión más reciente (1.1.0-7).
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 19
angelserver@srv-base-angel:~$
```

```
angelserver@srv-base-angel:~$ systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; enabled; preset:▶
   Active: active (running) since Tue 2025-07-22 11:55:21 CEST; 1h 18min ago
   Invocation: f358002f3451493eae9d062866aef64b
     Docs: man:fail2ban(1)
    Main PID: 1501 (fail2ban-server)
       Tasks: 5 (limit: 3407)
      Memory: 22.5M (peak: 31.5M, swap: 12M, swap peak: 12M)
         CPU: 6.272s
    CGroup: /system.slice/fail2ban.service
            └─1501 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

jul 22 11:55:21 srv-base-angel systemd[1]: Started fail2ban.service - Fail2Ban ▶
jul 22 11:55:22 srv-base-angel fail2ban-server[1501]: Server ready
lines 1-14/14 (END)
```

Después de aplicar el hardening, actualizaremos el sistema de nuevo con:

sudo apt update && apt full-upgrade

```
angelserver@srv-base-angel: ~
angelserver@srv-base-angel:~$ sudo apt update && apt full-upgrade
```

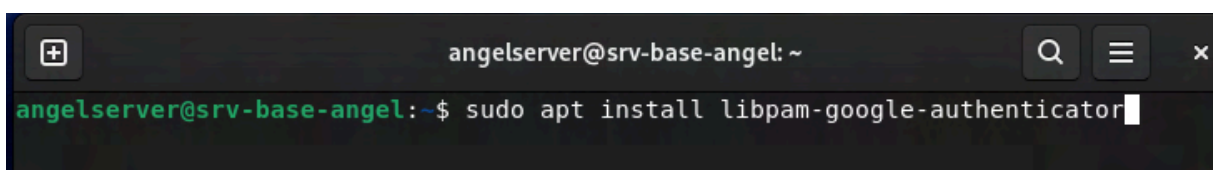
Fase 5: Reforzamiento y respuesta futura

En esta fase buscaremos implementar medidas permanentes de prevención y preparar una estrategia profesional de respuesta ante futuros incidentes.

Activar autenticación en dos factores (2FA) y segmentación de red

Instalaremos Google Authenticator para el 2FA:

sudo apt install libpam-google-authenticator

A terminal window with a dark background. The title bar shows 'angelsrver@srv-base-angel: ~'. The prompt is 'angelsrver@srv-base-angel:~\$' and the command entered is 'sudo apt install libpam-google-authenticator'.

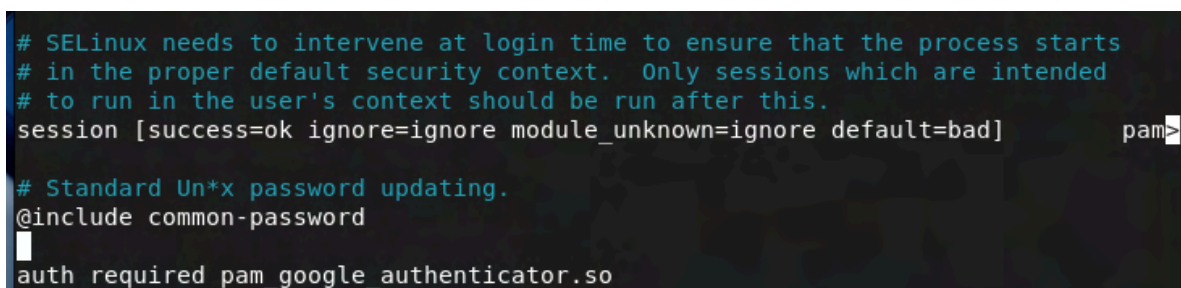
```
angelsrver@srv-base-angel:~$ sudo apt install libpam-google-authenticator
```

Edita PAM para integrar 2FA:

sudo nano /etc/pam.d/sshd

Añade al final:

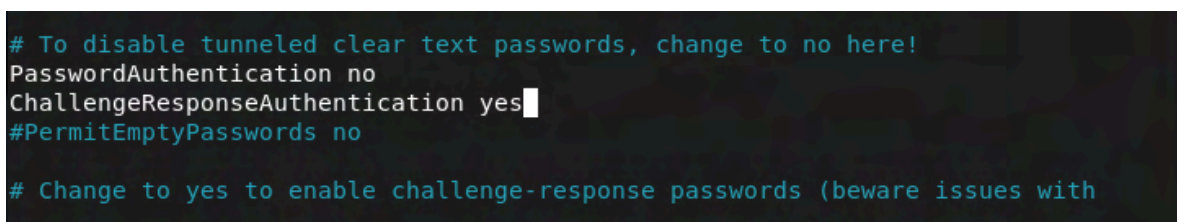
auth required pam_google_authenticator.so

A terminal window showing the contents of the file /etc/pam.d/sshd. The text is as follows:

```
# SELinux needs to intervene at login time to ensure that the process starts  
# in the proper default security context. Only sessions which are intended  
# to run in the user's context should be run after this.  
session [success=ok ignore=ignore module_unknown=ignore default=bad] pam  
  
# Standard Unix password updating.  
@include common-password  
  
auth required pam_google_authenticator.so
```

Edita SSH para requerir 2FA:

ChallengeResponseAuthentication yes

A terminal window showing the configuration of /etc/ssh/sshd_config. The text is as follows:

```
# To disable tunneled clear text passwords, change to no here!  
PasswordAuthentication no  
ChallengeResponseAuthentication yes  
#PermitEmptyPasswords no  
  
# Change to yes to enable challenge-response passwords (beware issues with
```

Reinicia SSH:

sudo systemctl restart sshd

Integrar un sistema de detección de intrusos (IDS)

El objetivo es detectar comportamientos sospechosos en tiempo real o retrospectivamente, para ello instalaremos OSSEC ejecutando:

sudo apt update

sudo apt install curl gcc make build-essential inotify-tools libevent-dev zlib1g-dev libpcr2-dev libssl-dev -y

```
angelserver@srv-base-angel:~$ sudo apt update
sudo apt install curl gcc make build-essential inotify-tools libevent-dev zlib1g-dev libpcr2-dev libssl-dev -y
Obj:1 http://archive.ubuntu.com/ubuntu plucky InRelease
Obj:2 http://security.ubuntu.com/ubuntu plucky-security InRelease
Obj:3 http://archive.ubuntu.com/ubuntu plucky-updates InRelease
Obj:4 http://archive.ubuntu.com/ubuntu plucky-backports InRelease
Todos los paquetes están actualizados.
curl ya está en su versión más reciente (8.12.1-3ubuntu1).
Los paquetes indicados a continuación se instalaron de forma automática y ya no son necesarios.
  linux-headers-6.14.0-22      linux-modules-extra-6.14.0-22-generic
  linux-headers-6.14.0-22-generic  linux-tools-6.14.0-22
  linux-image-6.14.0-22-generic  linux-tools-6.14.0-22-generic
  linux-modules-6.14.0-22-generic
Utilice «sudo apt autoremove» para eliminarlos.

Installing:
  build-essential  inotify-tools  libpcr2-dev  make
  gcc              libevent-dev  libssl-dev  zlib1g-dev

Installing dependencies:
  dpkg-dev      libasan8      libitm1
  fakeroot      libcc1-0      liblsan0
```

Este paso instalará las dependencias necesarias.

Después ejecuta:

curl -O https://github.com/ossec/ossec-hids/archive/refs/tags/3.8.0.tar.gz

tar -xvzf 3.8.0.tar.gz

cd ossec-hids-3.8.0

Ejecuta el instalador con:

sudo ./install.sh

Cuando se abra el asistente interactivo:

- Selecciona idioma: **[en]**
- Tipo de instalación: **local** (*monitorización en la misma máquina*)
- Activar monitoreo de integridad de archivos: **yes**
- Activar monitoreo de rootkit: **yes**
- Configuración por defecto: **yes**

Solo queda iniciar OSSEC con el comando:

`sudo /var/ossec/bin/ossec-control start`

Y verificar el estado del servicio con:

`sudo /var/ossec/bin/ossec-control status`

Conclusión

Tras una investigación completa del sistema comprometido, se determinó que el ataque se produjo mediante acceso remoto no autorizado, seguido de ejecución de scripts desde directorios temporales. Se detectó persistencia mediante tareas programadas y se evidenció escalada de privilegios.

Se procedió a:

- Aislar y clonar el sistema para análisis.
- Eliminar completamente los binarios maliciosos.
- Reinstalar servicios y aplicar hardening.
- Instalar sistemas de detección de intrusos y activar autenticación 2FA.
- Redactar un protocolo de actuación estructurado.

Gracias a las acciones realizadas, el sistema fue restaurado de forma segura, fortalecido y documentado para futuras respuestas rápidas ante incidentes